

MedaGama — Veri Koruma Uyumluluk Raporu

KVKK · HIPAA · GDPR — alınan teknik önlemler

Haziran 2026 · Sürüm 1.0

Özet

MedaGama bir sağlık platformudur; işlediği veriler "özel nitelikli kişisel veri" (sağlık verisi) kapsamındadır. Platform, KVKK, HIPAA ve GDPR'nin gerektirdiği teknik ve idari önlemleri uygulayacak şekilde tasarlanmıştır. Aşağıda alınan teknik önlemler ve durumları yer alır.

KVKK

Türkiye · teknik önlemler

HIPAA

ABD sağlık · teknik önlemler

GDPR

Avrupa · teknik önlemler

Uygulanan Teknik Önlemler

Alan	Alınan önlem	Durum
Açık rıza (sağlık verisi)	Kayıtta zorunlu onay + zaman/IP kaydı	TAM
Veli rızası (18 yaş altı)	Veli e-posta onayı zorunlu	TAM
PHI şifreleme	Hassas alanlar (not, tanı, anamnez, mesaj, doküman) şifreli	TAM
Parola güvenliği	bcrypt hash	TAM
Oturum güvenliği	Token süresi 120 dk (otomatik sonlanır)	TAM
Erişim kontrolü	Hasta yalnızca kendi verisi; doktor/klinik kendi kapsamı	TAM
Yetkisiz erişim (IDOR)	Tüm uçlarda kimlik+yetki doğrulaması	TAM
Denetim kaydı (audit log)	PHI erişimleri ve rıza işlenir	TAM
Veri erişim/taşıma hakkı	Kullanıcı verisini dışa aktarabilir	TAM
Silinme hakkı	Hesap + veri silme	TAM
Çerez onayı	Granular (analitik/pazarlama/yurtdışı ayrı)	TAM
Analitik gizliliği	GA anonim IP + sağlık URL'leri maskeli	TAM
Telehealth gizliliği	Bulut kaydı/transkript varsayılan KAPALI	TAM
Subprocessor şeffaflığı	Gizlilik sayfasında işleyici + yurtdışı tablosu	TAM
Veri saklama (retention)	Soft-delete + yasal süre sonu otomatik silme	TAM
İhlal bildirim altyapısı	Breach notification servisi	TAM

TAM

Uygulandı / aktif

Öne Çıkan Hassas Önlemler

- Telehealth (video görüşme): ses/video kaydı ve otomatik altyazı varsayılan olarak KAPALIDIR — hasta verisi üçüncü taraf bulutta saklanmaz. (İleride yalnızca yasal sözleşme + hasta açık rızası ile açılabilir.)
- Analitik: Google Analytics yalnızca kullanıcı onayıyla çalışır; IP anonimleştirilir ve doktor/klinik gibi sağlık bağlamı adresler maskelenir — sağlık verisi analitiğe sızmaz.

- Şifreleme: Tıbbi notlar, tanı, anamnez, mesaj içeriği ve dokümanlar veritabanında şifreli saklanır.
- Erişim: Her kullanıcı yalnızca yetkili olduğu veriye erişir; sistem her istekte kimlik ve yetki doğrular.

Tamamlanması Gereken Hukuki/İdari Adımlar

Teknik altyapı hazırdır. Aşağıdakiler yazılımla değil, hukuki/idari süreçle tamamlanır:

- Üçüncü taraf hizmet sağlayıcılarla (video, vb.) veri işleme/gizlilik sözleşmesi (BAA/DPA) imzalanması
- Telehealth kaydı açılacaksa hastadan ayrı açık rıza alınması (altyapı hazır)
- KVKK VERBİS (veri sorumluları sicili) kaydı
- Gerekliyorsa Veri Koruma Sorumlusu (DPO) atanması

Sonuç: Platformun veri koruma teknik altyapısı KVKK, HIPAA ve GDPR gereklilikleriyle uyumlu şekilde uygulanmıştır. Kalan maddeler hukuki/idari süreçlerdir ve yazılım dışıdır.

Not: Bu rapor, alınan teknik önlemleri özetler; hukuki uygunluk görüşü yerine geçmez. Nihai uyum için hukuk/veri koruma uzmanı değerlendirmesi önerilir.